HZ BOOKS 华章科技
ELSEVIER 爱思唯尔

信息安全技术丛书

Kali 渗透测试技术实战

[美] James Broad　Andrew Bindner　著
IDF实验室　译

Hacking with Kali
Practical Penetration Testing Techniques

- 国际著名信息安全专家亲笔撰写，IDF实验室成员倾情翻译，著译双馨。
- 全面而系统讲解Kali渗透测试的各种技术细节和方法，包含丰富示例，为快速掌握Kali渗透测试技术提供翔实的指导。

机械工业出版社
China Machine Press

信息安全技术丛书

Kali 渗透测试技术实战

Hacking with Kali: Practical Penetration Testing Techniques

（美）James Broad　Andrew Bindner　著

IDF 实验室　译

HZ BOOKS
华章图书

机械工业出版社
China Machine Press

图书在版编目（CIP）数据

Kali 渗透测试技术实战 /（美）布鲁德（Broad, J.），（美）宾得（Bindner, A.）著；IDF 实验室译 . —北京：机械工业出版社，2014.9
（信息安全技术丛书）
书名原文：Hacking with Kali: Practical Penetration Testing Techniques

ISBN 978-7-111-47320-6

I. K…　II. ①布…　②宾…　③ I…　III. Linux 操作系统　IV. TP316.89

中国版本图书馆 CIP 数据核字（2014）第 158926 号

本书版权登记号：图字：01-2014-1843

Hacking with Kali: Practical Penetration Testing Techniques.

James Broad and Andrew Bindner.

ISBN: 978-0-12-407749-2

Copyright © 2014 by Elsevier Inc. All rights reserved.

Authorized Simplified Chinese translation edition published by the Proprietor.

Copyright © 2014 by Elsevier (Singapore) Pte Ltd. All rights reserved.

Printed in China by China Machine Press under special arrangement with Elsevier (Singapore) Pte Ltd. This edition is authorized for sale in China only, excluding Hong Kong SAR, Macau SAR and Taiwan. Unauthorized export of this edition is a violation of the Copyright Act. Violation of this Law is subject to Civil and Criminal Penalties.

本书简体中文版由 Elsevier (Singapore) Pte Ltd. 授权机械工业出版社在中国大陆境内独家出版和发行。本版仅限在中国境内（不包括香港特别行政区、澳门特别行政区及台湾地区）出版及标价销售。未经许可之出口，视为违反著作权法，将受法律之制裁。

本书封底贴有 Elsevier 防伪标签，无标签者不得销售。

Kali 渗透测试技术实战

[美] James Broad　等著

出版发行：机械工业出版社（北京市西城区百万庄大街 22 号　邮政编码：100037）
责任编辑：吴　怡　　责任校对：董纪丽
印　　刷：　　版　　次：2014 年 9 月第 1 版第 1 次印刷
开　　本：186mm×240mm　1/16　　印　　张：11.75
书　　号：ISBN 978-7-111-47320-6　　定　　价：59.00 元

凡购本书，如有缺页、倒页、脱页，由本社发行部调换
客服热线：（010）88378991　88361066　　投稿热线：（010）88379604
购书热线：（010）68326294　88379649　68995259　　读者信箱：hzjsj@hzbook.com

版权所有 • 侵权必究
封底无防伪标均为盗版
本书法律顾问：北京大成律师事务所　韩光 / 邹晓东

The Translator's Words 译 者 序

“工具善其事，必先利其器”，当 BackTrack 系统基于电子取证和渗透测试的设计而逐渐成为信息安全人员炙手可热的 Linux 发行版本后，其功能更强大，系统操作更简洁，运行更稳定，最后一个版本是 BackTrack 5。已然熟悉和习惯了 BackTrack 系统的渗透测试人员完全没有必要因为 Kali 的出现而忧心忡忡，实际上 Kali Linux 在设计之初原本的命名是 BackTrack 6，只是再基于 Ubuntu 发行版进行修改以达到 Offensive Security 团队的设计目标显得工程尤为庞大，因此更替 Debian 作为基础系统后的 BackTrack 系统重新命名为 Kali Linux，即官方所称的“BackTrack Reborn”（BT 重生）。

相比其他的系统工具书籍，本书的内容不仅包括基础的 Kali Linux 安装、配置，而且涵盖信息安全爱好者和从业人员所关心的渗透测试实验环境的搭建、渗透测试生命周期以及渗透测试评估报告和模板的内容。无论是刚刚接触渗透测试的爱好者，还是从事信息安全行业的老手，相信都可以从中学到或了解到自己以往未知或未意识到的操作技能和渗透测试经验，毕竟本书作者 James Broad 拥有超过 20 年的一线 IT 从业经验。

值得注意的是，本书作者作为一名信息安全专家曾经为包括美国国防、执法机构、情报机构、金融和医疗保险行业提供过信息安全服务。而自 2013 年斯诺登事件后，从国家层面到企业层面都越来越重视信息安全及其在信息化发展中的重要性，以至于未来十年被很多人称为“信息安全的黄金十年”，本书的面世和引入虽不至于达到“师夷长技以制夷”，但至少可以在越加严峻的信息安全形势下，为诸多信息安全爱好者、从业者的成长与蜕变起到提点、引路的作用。

本书的翻译由 @IDF 实验室（www.idf.cn）成员裴伟伟、童进、封畅、李秀烈、张世会、成明遥共同完成，徐文博亦参与了部分审校工作。IDF 实验室一直致力于安全知识普及、安全人才培养、国际技术交流和黑客文化演绎，能够参与本书的翻译得益于 IDF 实验室联合创

始人万涛（@ 黑客老鹰）和机械工业出版社吴怡编辑的努力，同时感谢在翻译过程中吴怡编辑的耐心交流和经验提点。

由于本书内容涉及渗透测试的各个方面，一些术语尚无确切译法，我们保留了英文。部分章节翻译难度较大，加之参与翻译工作的各位 IDF 实验室成员水平有限，译文中如存在不当之处也在所难免。我们真诚地希望读者不吝赐教，如有任何的意见和建议请发邮件给我们：idf@idf.cn，我们将不胜感激。

IDF 实验室　裴伟伟（做个好人）

2014 年 5 月 23 日

HZ BOOKS
华章图书

Acknowledgements 致　　谢

我想把这本书献给我的家人：我的姐姐们 Lisa、Teresa、Mary，是她们一直在那里默默地支持我。感谢我的妻子 Dee 还有我的孩子 Micheal 和 Tremara，是你们给了我继续学习和成长的动力。还献给我的朋友们：Amber 和 Adam、Vince 和 Annette、Darla、Travis 和 Kim、Steve 和 Sharon，太多了无法在这里一一列出，不论是新朋友还是老朋友，是你们让我的生活变得更加精彩。

谢谢大家！

生命不息，奋斗不止——Jeff Olson

HZ BOOKS
华章图书

目　录 *Contents*

译者序
致　谢

第 1 章　引言 ····· 1

1.1　本书的读者群 ····· 1

1.2　本书中的图片、表格和屏幕截图 ····· 2

1.3　关于渗透测试 ····· 2

1.4　渗透测试生命周期 ····· 3

1.5　常见的术语 ····· 3

1.6　Kali 的发展史 ····· 6

参考文献 ····· 6

第 2 章　下载并安装 Kali Linux ····· 7

2.1　Kali Linux ····· 7

2.2　系统信息 ····· 8

2.3　下载 Kali ····· 9

2.4　安装在硬盘 ····· 10

HZ BOOKS 华章图书

2.5 安装在 U 盘 …… 17
2.6 安装在 SD 卡 …… 19
2.7 本章小结 …… 20
第 3 章 软件、补丁和升级 …… 21
3.1 APT 软件包处理工具 …… 21
3.2 Debian 软件包管理器 …… 24
3.3 TAR 压缩包 …… 26
3.4 Nessus 安装实用指南 …… 28
3.5 本章小结 …… 28
第 4 章 配置 Kali …… 29
4.1 概述 …… 30
4.2 网络基础知识 …… 30
4.3 使用图形用户界面来配置网络接口 …… 33
4.4 使用命令行来配置网络接口 …… 35
4.5 使用 GUI 来配置无线网卡 …… 36
4.6 Web 服务器 …… 39
4.7 FTP 服务器 …… 40
4.8 SSH 服务器 …… 42
4.9 配置并访问外置媒体 …… 43
4.10 更新 Kali …… 44
4.11 升级 Kali …… 44

HZ BOOKS 华章图书

4.12 添加软件库的源 ····· 45

4.13 本章小结 ····· 45

第 5 章 渗透测试实验环境 ····· 46

5.1 概述 ····· 46

5.2 搭建一个免费的实验环境 ····· 47

5.3 Metasploitable2 ····· 55

5.4 扩展实验环境 ····· 59

5.5 MCIR 训练套件 ····· 60

第 6 章 渗透测试生命周期 ····· 65

6.1 概述 ····· 65

6.2 阶段 1：侦察 ····· 66

6.3 阶段 2：扫描 ····· 67

6.4 阶段 3：渗透 ····· 67

6.5 阶段 4：维持访问 ····· 67

6.6 阶段 5：报告 ····· 68

6.7 本章小结 ····· 68

第 7 章 侦察 ····· 69

7.1 概述 ····· 69

7.2 先从目标网站开始 ····· 70

7.3 网站镜像 ····· 71

HZ BOOKS 华章图书

7.4 Google 搜索 …… 71
7.5 Google Hacking …… 76
7.6 社交媒体 …… 76
7.7 招聘网站 …… 77
7.8 DNS 和 DNS 攻击 …… 77
7.9 查询域名服务器 …… 79
7.10 区域传输 …… 80
参考资源 …… 80
第 8 章 扫描 …… 81
8.1 概述 …… 81
8.2 理解网络流量 …… 82
8.3 扫描神器：Nmap …… 86
8.4 选择端口 …… 95
8.5 Hping3 …… 96
8.6 Nessus …… 96
8.7 本章小结 …… 103
第 9 章 渗透 …… 104
9.1 概述 …… 104
9.2 Metasploit 介绍 …… 107
9.3 Metasploit 使用 …… 111
9.4 Web 渗透 …… 120

9.5 本章小结 …… 129

第 10 章 维持访问 …… 130

10.1 概述 …… 130

10.2 术语和核心概念 …… 131

10.3 后门程序 …… 133

10.4 键盘记录器 …… 140

10.5 本章小结 …… 140

参考资源 …… 141

第 11 章 报告和模板 …… 142

11.1 生成报告 …… 142

11.2 报告演示 …… 144

11.3 报告和证据保存 …… 144

11.4 本章小结 …… 144

附录 A Tribal Chicken 工具 …… 145

附录 B Kali 渗透测试工具集 …… 158

HZ BOOKS 华章图书

第 1 章 Chapter 1

引　言

章节信息

- 本书的读者群
- 本书图片、图表和屏幕截图
- 常用术语
- Kali Linux 发展史

本书要点

本书通过指导读者使用现今流行的最先进的 Live 版操作系统 Kali Linux，引领读者贯穿渗透测试整个生命周期。在简短介绍后，本章将详述如何寻找、下载、安装并定制 Kali Linux。接下来简要介绍 Linux 的基本配置和设置，以保证读者能理解基本命令和设置。本书剩余部分用于介绍渗透测试的生命周期——侦察、扫描、渗透、维持访问和报告等阶段。Kali Linux 的发行版带有成百上千种不同的工具，而本书在介绍渗透测试生命周期时将仅涉及对应生命周期阶段最常用的工具。报告阶段会详细介绍如何生成报告，包括将渗透测试结果呈现给管理层和领导的报告，还包括开始渗透测试前的授权合同（ROE）模板。

1.1　本书的读者群

专业技术人员

计算机专业领域的技术人员，通过了解渗透测试人员的工作过程，能够获取更多经验。

HZ BOOKS 华章图书

专业技术人员将会进一步理解渗透测试人员使用到的基本概念和技术，这些知识能让他们的信息系统更安全。这些领域包括但不限于服务器管理员、网络管理员、数据库管理员和桌面支持人员。

某些希望转型为专业渗透测试人员的专业技术人员通过阅读本书，可以获得大量渗透测试方面的知识。由于专业技术人员对各领域的知识有深入把握，在成为渗透测试人员时会具有独特的优势。在服务器管理方面拥有大量知识的人员会比渗透测试人员更适合测试服务器的安全配置。在其他专业领域的人员也是如此。

本书将会向专业技术人员介绍渗透测试领域以及渗透测试人员的常用工具。通过学习下面章节的例子和指令，专业人员将可以转型为渗透测试人员。

安全工程师

安全工程师的目标是努力使开发和维护的系统更加安全，如果理解了渗透测试的思维观念和生命周期，将会获得大量的知识，这将有利于总结提炼所开发和支持系统的安全特征。

信息安全和信息工程专业的学生

理解渗透测试领域，有助于学生深入了解当今报酬最高、最令人沮丧、最专业的信息技术领域之一：渗透测试。尽早接触渗透测试，可使学生确定把渗透测试方向作为职业是一个好的选择。

本书不适合的人群

本书不会为攻击美国国家安全局（NSA）或者本地银行分行提供技能和经验，也建议你不要去尝试。本书也不是为拥有多年渗透测试经验和深入掌握 BackTrack/Kali Linux 中工具原理的专业人员准备的。任何人都不能违法，本书引导更多的人接触渗透测试，是为了追求更安全的信息系统。

1.2 本书中的图片、表格和屏幕截图

本书中的图表是为了提供更坚实的理解，这是对文字描述的基本概念和技术的图解说明。

贯穿全书的屏幕截图用于说明将在 Kali Linux 环境中执行的命令和动作，也用于进一步阐明所述主题。根据 Kali Linux 的配置和版本的不同，这些屏幕截图与本地显示可能会有少许不同。这不影响渗透测试的基础学习，即使有影响，也应该是轻微的。

1.3 关于渗透测试

渗透测试是令人激动和内容丰富的领域，本章只是一个引言。渗透测试，或者更简洁地

说渗透，是一套技术过程和方法论，是技术专家模拟黑客的动作和技术去尝试利用网络或信息系统。本书将会带领读者沿着渗透测试人员的步骤一步步地跟进：形成对目标的理解，分析目标，并试着渗透。本书用一章总结了报告撰写和其他文档，这些文档用于向组织领导层表述渗透测试团队的活动以及发现的系统缺陷。最后一章包括一个规范化的授权协议（ROE）模板，应该在渗透测试开展前进行标准化并经过审批。仅对授权的系统实施渗透测试以及严格按照审批的授权文件（ROE）需求进行渗透，这点很重要。

1.4 渗透测试生命周期

在实践中有众多不同的渗透测试生命周期模型。目前为止，最受认可的是 EC-Council Certified Ethical Hacker（EC C|EH，伦理黑客认证）定义和使用的方法和生命周期。整个过程包含五个阶段：侦察、扫描、获取访问、维持访问以及清除痕迹[1]。本书将遵循 Patrick Engebretson 发行的《 The Basics of Hacking and Penetration Testing》一书中渗透测试生命周期的修订版。这个过程采用了 C|EH 使用的基本阶段但是不包括最后阶段：清除痕迹。从本书中删除这个阶段是特意为之，因为最终阶段的许多技术在更深入的书中有出色的解释。

1.5 常见的术语

当提及渗透测试时，有很多常用术语需要讨论。不同的专业、技术领域，甚至是同一团队成员对该领域术语的理解都会稍有不同。因此，本书将使用下面的术语和相关定义：

渗透测试

渗透测试是测试人员在具体和授权的指导原则下尝试规避信息系统的防护措施所使用的方法、过程和规程，包括突破系统集成的安全特性。这种测试与技术评估、管理、操作设置和系统控制有关。通常情况下，仅评估信息系统建立时的安全性。目标网络系统管理员和技术人员或许不知道渗透测试正在进行。

红客团队

红客团队在方法和技术上模拟潜在对手。它们通常比渗透测试团队要大，范围也更广。渗透测试本身就是红客团队活动的一个子集，但是这些活动测试了一个组织安全部分的其他功能。红客团队通常采用安全技术、社会工程技术和物理方式攻击一个组织，通常使用与黑帽黑客同样的技术测试一个组织或者信息系统针对黑客攻击行为的防护措施。红客团队除了渗透测试外，他们还会执行社会工程攻击，包括网络钓鱼和鱼叉式网络钓鱼，还有可能发动物理攻击，包括翻垃圾桶或者物理开锁等方式获得所需要的信息。在大多数情况下，

这是由一个小组进行工作，目标组织的工作人员并不知道红客团队的工作已经在进行。

伦理黑客（Ethical Hacking）

伦理黑客是专业的渗透测试人员，他们代表系统所有者或拥有信息系统的组织来攻击系统。在本书中，伦理黑客与渗透测试人员是同义词。

白帽子

是指专门从事提高信息系统安全性的伦理黑客或者计算机安全专业人员，白帽子是一个俚语。

黑帽子

黑帽子是一个俚语，指在没有授权的情况下，使用科技技术绕过系统的安全措施进行计算机犯罪的人。当执行授权检验或测试时，渗透测试人员使用的技术与黑帽子相同，但黑帽子进行的操作未得到授权，属于违法行为。

灰帽子

灰帽子是介于白帽子和黑帽子之间的技术专家。他们通常在没有授权的情况下，尝试绕过信息系统的安全功能，不是为了获利而是为了将发现的脆弱性通知系统管理员。灰帽子通常没有测试系统的授权，但他们并不追求个人利益或金钱收入。

漏洞评估与漏洞分析

漏洞分析用于评估信息系统的安全设置。这类评估包括系统使用和缺失的安全补丁评估。漏洞评估团队，简称 VAT，可以是独立于信息系统之外的团队，也可以是信息系统支持团队的部分成员。

安全控制评估

安全控制评估用于评估信息系统是否符合特别法律或法规要求。例如这些要求包括但不限于《 the Federal Information Security Management Act》（FISMA）、《 the Payment Card Industry》（PCI）和《 Health Insurance Portability and Accountability Act》（HIPAA）。安全控制评估可作为 BOE（the Body of Evidence）的一部分，企业在生产环境中使用 BOE 来授权信息系统工作。某些系统需要渗透测试作为安全控制评估的一部分。

恶意用户测试

在恶意用户测试中，评估人员假定内部的信任用户出现了一个恶意用户，进行了恶意操

作。在这些测试中，评估人员获得一个授权用户或管理员用户的证书，通常是一个测试账户。评估人员会使用这些证书尝试绕过安全限制，包括测试账户未授权的文档查看和设置权限，改变本不该改变的设置，提升账户权限。恶意用户测试模拟了内部信任用户的欺骗行为。

社会工程

社会工程包括试图欺骗系统用户或管理员做社会工程师感兴趣，而超越其访问权利之外的事。社会工程攻击损害信息系统或用户。社会工程师利用了人们固有的帮助他人的愿望，使信息系统遭到入侵。通常的社会工程技术包括试图帮助咨询台分析情况，重置用户账户密码，或使最终用户泄漏密码，使用未授权的账户登录系统的目的。其他的社会工程技术包括网络钓鱼和鱼叉式网络钓鱼。

网络钓鱼

网络钓鱼（Phishing，英文发音类似于 fishing）技术试图获得目标对象公开的个人信息，例如用户名，账号和密码。这常借助假冒来自真实公司、银行和客户支持人员的电子邮件来实施。其他形式的网络钓鱼还有，尝试在用户毫不知情的情况下，引导用户单击虚假的超链接，使恶意代码安装到目标机器上。该恶意软件会从计算机中删除数据或控制计算机攻击其他机器。网络钓鱼的目标通常不是特定用户，而是邮件列表中的用户或具有特定地址后缀的电子邮件，例如每个以“@foo.com”结尾的用户。

鱼叉式网络钓鱼

鱼叉式网络钓鱼是网络钓鱼的一种，它针对特定用户。例如，攻击者研究如何找到首席执行官（CEO）和其他高管的 email 地址，也仅对他们进行钓鱼攻击。

翻垃圾桶

过滤系统用户和管理员丢弃的垃圾，寻找有利于更进一步了解目标系统的信息。这些信息可能是系统配置和设置、网络拓扑图、软件版本和硬件组件、用户名和密码等。这个术语指进入大型垃圾箱，但若有机会，“深挖”小型办公室的垃圾箱同样也可以获得丰富的信息。

发行版（Live CD，Live 盘）、系统启动盘（Live OS）

Live CD 或 Live 盘是一张光盘，包含了整个操作系统。这些光盘对许多评估人员有用，它们可以被修改以集成特定软件组件、设置和工具。这些 Live 盘通常基于 Linux 发行版，或微软公司早期发行的几个 Windows 版本。基于信息系统的设置，Live 盘或许是评估人员或测试人员唯一可携带用于评估的设备，因为目标计算机系统能够被 Live 盘引导，实现信息系统资产的自我评估。

1.6 Kali 的发展史

Kali Linux 是 Offensive Security 社区最近发行的 live 盘安全版本。这个版本拥有超过 300 个安全和渗透测试工具，以渗透测试人员和其他人员使用频率和对评估信息系统是否有帮助来进行分组。与 Offensive Security 早期发行版本不同的是，Kali Linux 基于 Debian7.0 发行版。Kali Linux 延续了其前任 Backtrack 血统，也是由同样的团队提供支持。根据 Offensive Security 介绍，名称的变化表明公司已经对 Backtrack 发行版做了全新重构。与早期 Backtrack 发行版相比，巨大的改进值得重新命名，以示这不仅仅是 Backtrack 的新版本。Backtrack 本身也是基于两个安全工具基础上进行改进，源于 White Hat、SLAX（WHAX）和 Auditor。在这方面，kali Linux 是行业安全审计和渗透测试评估工具最新的化身。

参考文献

[1] ＜http://www.eccouncil.org＞.

[2] The basics of hacking and penetration testing: ethical hacking and penetration testing made easy (Syngress Basics Series).

HZ BOOKS
华章图书

第 2 章 Chapter 2

下载并安装 Kali Linux

华章图书

章节信息

- 本章将要介绍如何获得最强大的渗透测试工具包之一的 Kali Linux

本章要点

本章将要讲解按以下三种方式下载和安装 Kali Linux 的步骤：

- 硬盘
- USB 存储器
- SD 卡

2.1 Kali Linux

对一些高级用户而言，安装一个操作系统轻而易举，比如微软的 Windows、苹果的 OSX，或者像 Debian 和 Ubuntu 这样的开源系统，但是回顾一下安装过程总是有好处的。对于那些以前从来没有装过操作系统的人也不用担心，本章后续内容将提供搜索、下载和安装 Kali Linux 所需的所有步骤。

Kial Linux 在很多方面都很特别，该发行版最重大的不同之处在于，除了具有从硬盘安装运行和从 Live 盘引导的能力外，还默认安装了很多不同类型的专业应用程序。Live 盘是指装有操作系统的光盘，包括 CD、DVD、Blu-RayDisk。作为一个渗透测试人员，从 Live 盘启动系统的能力非常重要。因为即使渗透测试人员没有系统账户，他们也能够借助 Live 盘访问网络上的本地计算机来操作那些机器。这些系统将从 Live 盘引导，而非本地硬盘；也就是

说如果这些机器配置正确，那么渗透测试人员将可以访问本地网络上的资源，但是在本地机器硬盘上不会留下任何痕迹。安装在 Kali Linux 上的那些软件是 Kali Linux 独特的另一个原因，为渗透测试人员提供全套工具。Kali Linux 默认安装了 400 个渗透测试安全工具、软件包和应用程序，还能添加更多需要的程序。

2.2 系统信息

在初始安装和设置时，所有的操作系统都有唯一的细微的区别，但是，大多数 Linux 或者基于 Unix 平台的操作系统实际上比较相似。当安装 Kali Linux 时，像安装其他 Linux 操作系统一样，安装前的规划是关键。下面简短列出安装 Kali Linux 需要考虑的内容：

- 该操作系统运行在台式机还是笔记本？
- 需要多大的硬盘空间？
- 要使用的硬盘是否有足够的可用空间？
- 需要几个硬盘分区？
- 是否需要考虑日志管理问题？
- 是否需要考虑安全？

选择需要安装的硬件平台

通常情况下，操作系统是装在计算机的硬盘上，然而，像 Kali Linux 这种操作系统能安装到拇指驱动器（又名闪存驱动器）和 SD 卡上，因为近些年来出现了大容量设备，使得 Kali Linux 具有这种能力。除了选择用于安装操作系统的存储设备外，关键要决定是安装到独立的计算机上（比如实验室的计算机）还是允许移动的笔记本上？

如果到非常具体的硬件，比如系统用来做密码破解，需要高性能显卡，那么推荐把 Kali Linux 安装到台式计算机上。如果需要把操作系统从一个客户点搬到另一个客户点，或者是想测试无线设备，那么推荐安装到笔记本上。台式计算机和笔记本的安装步骤一样。

硬盘的选择

不是过分强调，但是容量大小确实很重要。一般的经验是硬盘越大越好，本书推荐最少使用 120GB 容量的硬盘；然而，即使这么大也很快会用完，尤其是在密码破解、取证和做渗透测试项目的情况下，要求获得控制权限，大量生成数据、收集证据、生成日志和报告。大多数商业和政府机构做安全评估时，操作系统要求被清理、擦除，或者完全移除以保持一个纯净的基线环境。这种做法被整个安全社区广泛接受，因为需要去合理处理客户机密数据和最小化损害公司基础设施的可能性。

磁盘分区

分区是通过设置一定量的块大小和扇区将文件系统格式化成硬盘特定区域的行为。分区能够预防接管系统的日志文件破坏操作系统，在一定条件下提供更好的安全。操作系统处于最底层（basic level），划分成两个不同的部分：第一部分是交换区，用于内存分页（memory paging）和存储；第二部分设计成用于其他所有活动，使用扩展文件系统 3（EXT3）或扩展文件系统 4（EXT4）文件结构进行格式化。就笔记本来说，尤其是那些一次又一次重装操作系统的机器，进一步（further partitioning）分区是没有必要的。对于用户自定义安装和那些操作系统使用时间更长的计算机，至少需要分离出临时文件。

硬盘的高级分区和双引导系统不在本书的讨论范围之内，将不作详细介绍。在附录 A 中将介绍如何使用第三方应用程序 Tribal Chicken 自定义分区。

安装过程中需要遵循的安全策略

Kali Linux 是非常强大的操作系统，预装了大量能够摧毁计算机、网络基础设施的工具，而如果使用不当或不道德，会导致犯罪行为或触犯法律。因为这个原因密码必不可少，虽然使用密码是最基本的安全习惯，但是很多管理员和安全专业人员经常忘记或忽视密码的使用。密码的适当使用是你安装的 Kali Linux 不被别人（那些可能无意或恶意损害个人、计算机或网络的人）使用的基本保障。

2.3　下载 Kali

Kali Linux 是 Linux 系统的一个发行版本，提供 ISO（发音读作 eye-so）文件格式下载。在安装之前需要从另一台计算机上下载下来，然后刻录到光盘。在写本书的时候，Kali Linux 可以从站点 http://www.kali.org/downloads/ 下载（图 2.1 所示）。关于高级操作、配置和特殊案例的文档也可以从 Kali 的官方网站 http://www.kali.org/official-documentation/ 下载。官方网站是一个非常大且活跃的社区，在这里用户可以提问题，也可以帮其他用户解决难题。推荐注册该网站以获得 Kali Linux 的创建者 Offensive Security 管理的社区公告板的访问权。OffensiveSecurity 会发送关于 Kali 的升级信息和社区信息。

确保选择了正确的体系架构（architecture）（i386=32 位，amd64=64 位）。Kail Linux 的版本很多，在此不做讨论，如果你期望获得熟悉的 Kali 或者需要一个更好控制的沙盒环境，那么下载 VMwar 版本很适合这种情形。点击相应选项的下载链接进入下一步。

对微软 Windows7 用户，双击完整下载，然后刻录 ISO 向导将出现。根据提示完成 ISO 镜像到 DVD 的转换，转换所得 DVD 盘可用来安装系统。Linux 用户需要在合适的磁盘刻录应用程序中打开 ISO 镜像，比如 K3b。

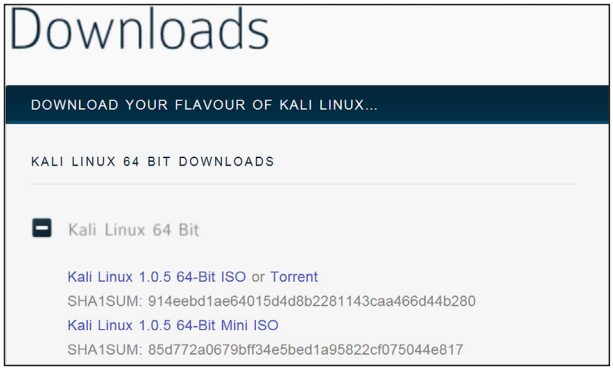


图 2.1　下载 Kali Linux

2.4　安装在硬盘

后面章节将提供文本和图形界面的安装向导。要正确地从系统硬盘安装 Kali 操作系统，或者从 Live 盘引导，关键在于启动时从基本输入输出系统（BIOS）选项中选择光盘启动。开始安装前，将 CD 放入电脑的 CD 托盘，然后从光盘启动电脑。高级用户可以使用合适的虚拟化技术，比如 VMware 的 Player 或 Oracle 的 VirtualBox，这类向导通俗易懂，对于创建 Kali Linux 虚拟化版本也有帮助。

第一次启动 Kali

电脑成功启动 Kali Linux 盘，屏幕显示类似图 2.2 所示画面。本书使用的 Kali Linux 版本是 1.0.5 64 位，不同时期下载的版本可能有轻微差别，但是图形安装画面十分相似。Kali Linux 每一个新版本的升级教程在 http://www.kali.org/ 站点可以找到，而且强烈推荐在安装前查阅这个站点中最近更新的文档，或在安装出现问题时查阅文档。

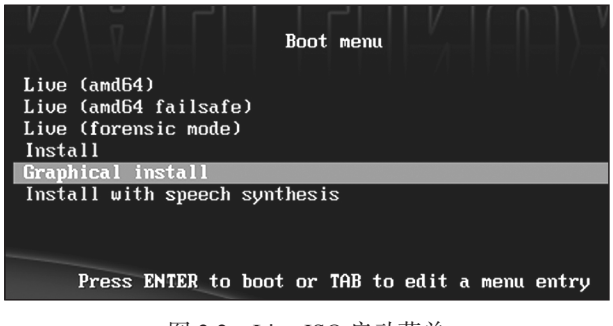


图 2.2　Live ISO 启动菜单

Kali Linux 以 Live CD（又叫 Live ISO）形式发行，意思是操作系统除了从硬盘安装启动外还可以直接从光盘运行。从 Live 盘运行 Kali Linux 允许启动系统，并且上面安装的所有工

具都会运行；但是当前的操作系统是临时的。临时是指一旦计算机关机，任何内存、保存的设置、文档、一些很重要的工作或者研究都会丢失。在临时状态下运行 Kali 需要非常谨慎，小心处理，需要正确理解 Linux 命令和操作系统。这种方法非常适合用来学习 Linux 操作系统，无需删除计算机的硬盘上已经安装的现有操作系统。

另一种安装方式是语音合成安装（Installation withSpeech Synthesis），这超出了本书的讨论范围。这是 Kali 和 Debian 操作系统新增的功能。如果你硬件环境支持语音合成，可以使用语音控制来安装。本书重点介绍图形界面安装；因此，选中“Graphical Install”，按 Enter 键。

安装过程中的默认设置选项

后面几步将为系统选择默认语言，位置和键盘格式。选择合适的设置，然后单击“Continue”按钮继续安装。当计算机开始安装 Kali Linux 时，整个安装过程中在屏幕上会出现各种进度条。对于大多数选项推荐使用默认设置。

初始化网络设置

如图 2.3 所示，详细显示了初始状态下，网卡的默认设置和基本配置。点击输入框选择一个主机名，然后点击“ Continue”。主机名应该是唯一的，如果不小心将居于同一网段的主机配成相同的主机名将导致一系列复杂的网络问题。



图 2.3　设置主机名

选中一个主机名后点击“ Continue”按钮，下一步将要求填写主机有效的完整域名（fully qualified domain name，FQDN）。这要求加入域名环境，而在大多数实验环境中这不是必需的。在本教程中，FQDN 空白不填，按“Continue”按钮绕过，继续安装。

设置密码

安装向导下一步要求设置一个 root 级别的密码。这个默认密码是：toor。但是，推荐设

置一个新密码，大小写字母、数字和特殊符号，每种字符至少包含一个。该密码对用户来说不应该具有可追踪性等，要难以猜解。建议大于等于 10 个字符长度。例如，某用户曾经在高中时踢过足球，那么不建议使用“ soccer22”作为密码。密码可以从常用短语衍生，便于增强记忆。在这里举一些强密码的例子：

- St0n(3)b@tt73-“Stone Battle”
- P@p3r0kCur5#-“Paper, Rock, Curse”
- m!gh7yP@jjjama%h-“Mighty Pajamas”

当你输入密码时，将显示一串点号或者星号。这属于正常情况，隐藏你的密码防止别人正注视着你的电脑屏幕。输入相同的强密码两次之后，点击“ Continue”按钮继续安装（如图 2.4 所示）。

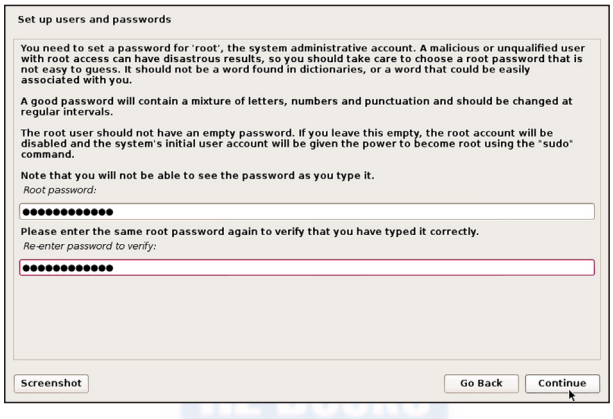


图 2.4　设置密码

配置系统时钟

图 2.5 所示提示选择时区。选择合适的时区然后点击“Continue”按钮推进安装。

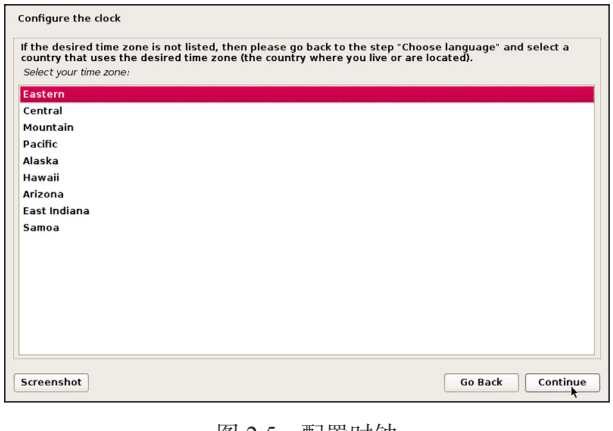


图 2.5　配置时钟

磁盘分区

配置一个 Linux 操作系统分区的方式有很多种，有些书籍专门用来介绍这些方法。本书着重介绍最基本的方式，向导式分区。从图 2.6 到图 2.10 高亮选项表示默认设置。直到图 2.10，之前这些步骤按默认设置就好。最后点击“Continue”按钮加速安装直到分区完成，但是，聪明人会花点时间回退检查安装向导的每一步。

图 2.6 显示了在安装期间对硬盘分区不同的操作。LVM或者叫逻辑卷管理（Logical VolumeManagement），不建议在笔记本、拇指驱动器或者 SD 卡安装中使用。LVM 是多硬盘分区模式，仅推荐高级用户使用。一般用户建议选“Guided-user entire disk”。点击“Continue”按钮继续下一步操作。

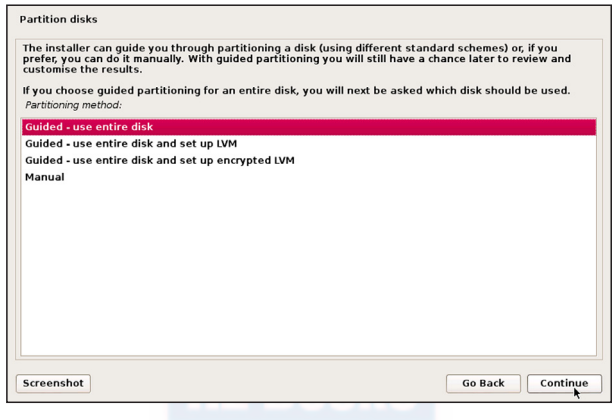


图 2.6　磁盘分区——1

图 2.7 显示了已选定用来安装的硬盘分区。根据硬件和 Kali Linux 的版本不同，安装过程可能稍有不同。硬盘分区选好后点击“Continue”按钮推进安装过程（如图 2.8 所示）。

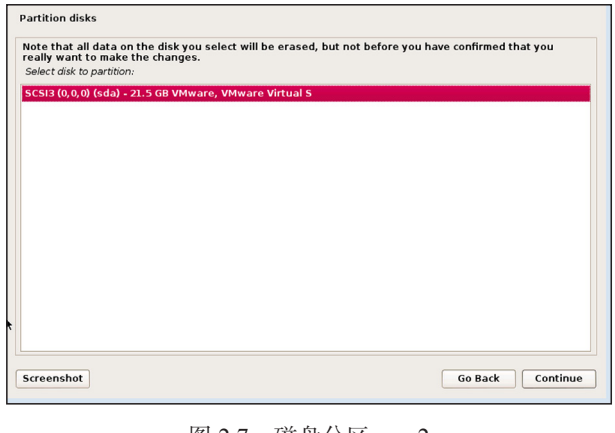


图 2.7　磁盘分区——2

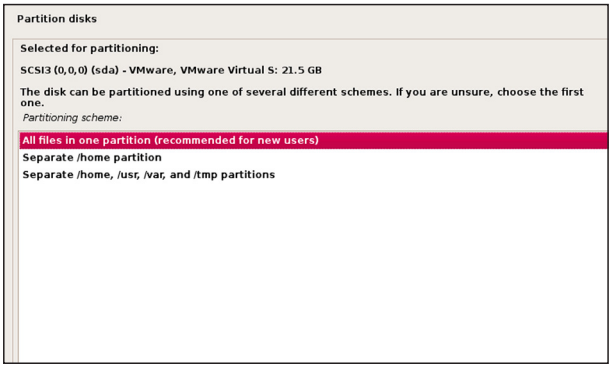


图 2.8　磁盘分区——3

本书主要是针对 Kali Linux 新用户，该步骤中推荐选择“All files in one partition（recommended for new users）”这一项。继续点击“Continue”按钮。

安装向导下一步显示内容是，分区向导已经完成，并且回顾了前面那些步骤中的设置。一个包含所有系统、用户和一些脚本文件的主分区将会被创建成一个分区。第二个分区将被创建作为交换区。这个交换区域是虚拟系统内存，用于将页面文件在中央处理器 CPU 和随机存储器 RAM 之间换入换出。所有的 Linux 系统都推荐使用交换区，一般的做法是设置交换区大小为安装在计算机上的物理 RAM 大小，或者是它的 1.5 倍。正如图 2.9 中所见，“Finish partitioning and write changes to disk”选项默认选定。依然按“Continue”按钮往下执行。

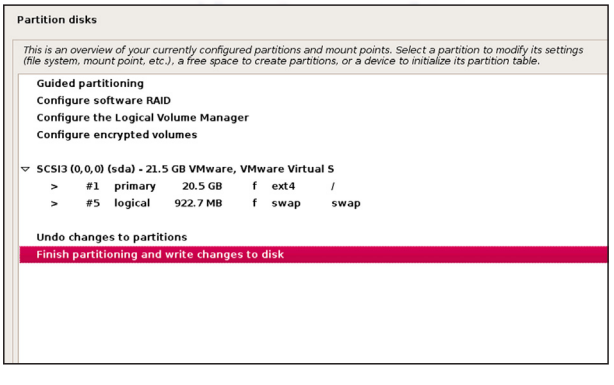


图 2.9　磁盘分区——4

如图 2.10 所示是最后一次在设置生效之前有机会检查之前的一切配置。如果需要更改分区大小，装好以后会有很多办法，但是如果操作不正确，可能损坏系统。该步骤中会出现一些警告信息，将要写入一些数据到你之前选好的磁盘分区表中。选择“YES”，然后点击“Continue”按钮继续安装过程。

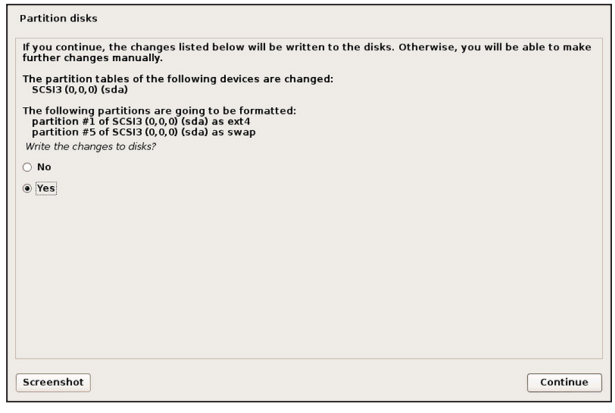


图 2.10　磁盘分区——5

然后点击安装向导分区模块的最后一个“ Continue”按钮，硬盘分区操作将开始。图 2.11 显示了实际安装的进度。依赖于你所持硬件设备，这个过程可能会花费几分钟或者一个小时甚至更多。

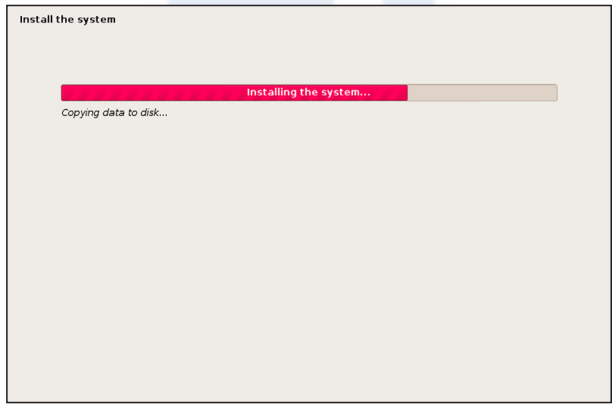


图 2.11　正在安装

配置软件包管理器

配置软件包管理器是设置操作系统很关键的一步。软件包管理器指向 Kali Linux 用于更新和打安全补丁的升级库。推荐使用 Kali Linux ISO 自带的网络镜像文件，因为那是最新的软件包管理源。图 2.12 所示默认选中“ Yes”选项。还是点击“ Continue”按钮继续安装过程。

如果使用代理，那么在安装向导的下一步提示中填上配置信息，否则空着就好，如图 2.13 所示，点击“Continue”按钮继续安装过程。

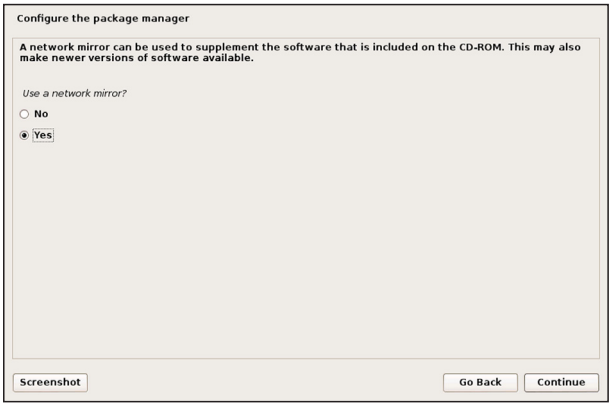


图 2.12　配置包管理器

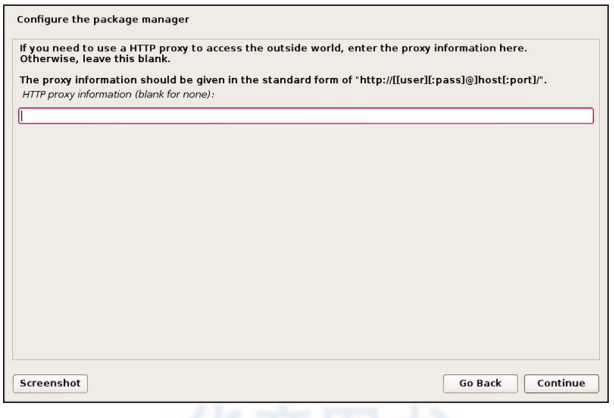


图 2.13　配置代理服务器

安装 GRUB Loader

计算机每次启动出现的那个画面就是 Grand Unified Bootloader（GRUB）。允许在系统加载之前去确认引导步骤的某些设置，可以随时修改设置，并且使之生效。强烈建议多数用户安装 GRUB，但是对一些高级用户可以不装。图 2.14 中已选择了“ YES”以便安装 GRUB。点击“Continue”按钮继续安装过程。

完成安装

现在将光盘从计算机取出，然后重启电脑。当出现图 2.15 所示提示时，点击“Continue”按钮完成安装。

然后再重启，将会出现欢迎页面。使用 root 用户和前面安装过程中设置的密码登录系统。成功登录，欢迎来到 Kali Linux 世界！

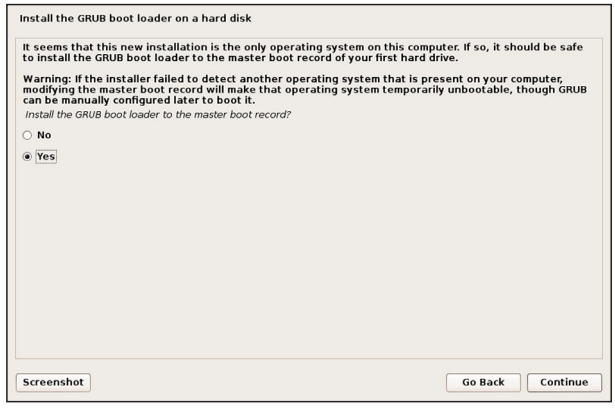


图 2.14　安装 GRUB

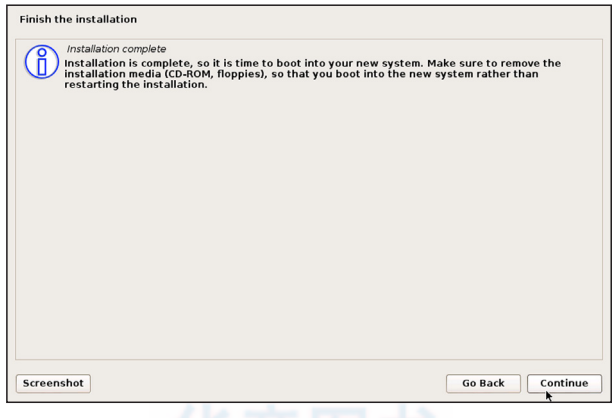


图 2.15　安装完成

2.5　安装在 U 盘

USB 存储设备，通常称为拇指驱动器或者其他名字，其实就是一个通过 USB 接口连接到计算机的存储设备。在这本书中，作者建议使用一个至少 8GB 空间的 USB 设备，而且空间越大越好。比较新的计算机设备可以设置从 USB 启动。如果你想把 Kali 安装在你的 U 盘上，那么首先要确认你的计算机支持从 USB 设备启动。

以下两节将会分别介绍如何在 Windows 和 Linux 平台上将 Kali Linux 安装在 USB 上。在此之前请一定要检查 Kali 官方主页上最近的文档更新。

在介绍你的 USB 设备用来做启动盘之前，有两个非常重要的术语需要科普一下：永久性和非永久性。永久性就是指即使设备在断电后你的程序或修改后的文档依然保留在设备上。非永久性是指设备在断电或重启后，所有的设置、自定义设置和文档都会丢失。这本书的特别之处在于，我们将从 Windows 平台上为你介绍非永久性安装，从 Linux 平台上介绍永久性安装。

Windows 系统上安装（非永久性安装）

需要使用到的应用程序：Win32DiskImager，下载地址：http://sourceforge.net/projects/win32diskimager/。

下载完 Kali Linux 的 ISO 文件后，把 U 盘插在计算机上并让 Windows 自动检测，注意此时系统分配给 U 盘的驱动器盘符。接下来打开 Win32 Disk Imager，点击文件夹图标浏览磁盘文件并找到 Kali 的 ISO 文件，然后点击“ OK”按钮。从设备下拉菜单中选择正确的驱动器盘符，然后点击“Write”按钮。

刻录完成后，重新启动计算机并从 BIOS POST 菜单中选择从 USB 启动，不同的设备厂商使用不同的方法来引导 USB 设备，请务必查阅你计算机厂商的相关文档。

Linux 系统上安装（永久性保存）

若要建立一个永久性保存的 U 盘启动盘，空间大小很重要，并且空间越大越好。另外，需要确保你的 Linux 系统版本中已经安装了 GParted 程序。如果在安装 GParted 时遇到困难，请检查操作系统的文档。如果没有安装，以下方法可能会帮助你检查：

- apt-get install gparted
- aptitude install gparted
- yum install gparted

下载完 Kali Linux 的 ISO 文件后，把 U 盘插在计算机上。打开一个终端窗口并输入以下命令来检查 USB 设备的位置：

```
mount | grep -i udisks |awk '{print $1}'
```

如图 2.16 所示，命令输出为“ /dev/sdb1”。根据你计算机的设置和配置文件的不同，该 USB 设备位置的输出也可能是不同的。在下一条命令中，使用匹配识别到的“ sdb”，后面不带任何数字。



图　2.16

接下来，使用“ dd”命令来把 Kali ISO 镜像文件传输到 USB 设备（过程会持续 5-10 分钟）：

```
dd if=kali_linux_image.iso of=/dev/sdb bs=512k
```

传输完成后，我们启动 GParted：

```
gparted /dev/sdb
```

此时，U 盘至少已经有了一个已经安装了 Kali 的分区，然后我们使用图形化界面添加新的分区后，应用待执行操作，保存退出。如图 2.17 所示。

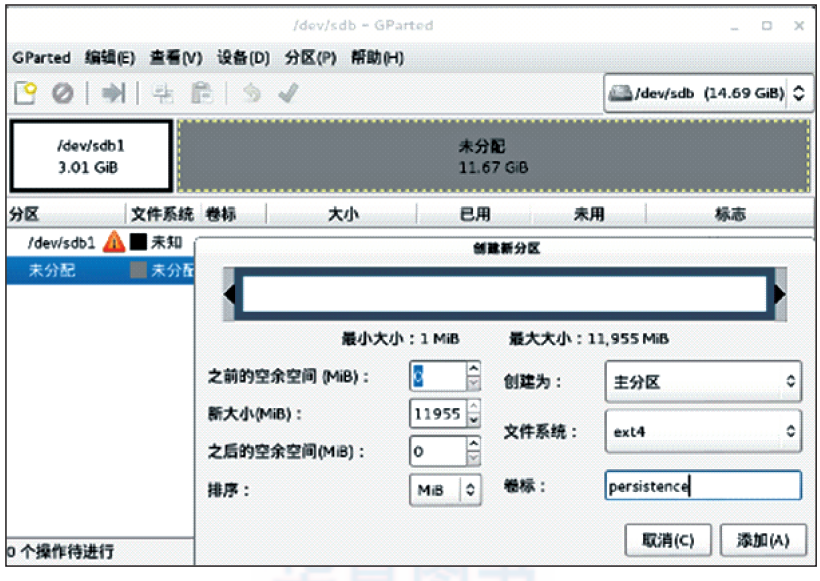


图 2.17　安装后信息

为了添加永久性保存配置功能，我们需要执行以下命令：

```
mkdir /mnt/usb
mount /dev/sdb2 /mnt/usb
echo "/ union" >> /mnt/usb/persistence.conf
umount /mnt/usb
```

现在已经完成了 Live USB 启动盘的制作，我们可以重启计算机从 USB 启动盘启动系统。

2.6　安装在 SD 卡

像 RaspberryPi 和 Google’s Chrome Notebook 这些微型计算机设备可以在 SD 卡上运行。

这些小型设备有很多用处，主要取决于你的想象力。像 Rasphberry Pi 这种设备最大的优点是便宜，因此受到开源社区用户的亲睐，使得全世界的能工巧匠们都能轻而易举地获得这

些资源。

Kali Linux 安装到 ARM 设备上的一个缺点是安装镜像需要定制，必须每一份硬件定制一个。提供给 ARM 的镜像可以从 Kali 的官方下载网页 http://www.kali.org/downloads/ 下载。在网站上查阅一下，是否有支持你的硬件设备的镜像下载。

下面几个步骤简单介绍下在基于 ARM 架构的设备上安装 Kali Linux。

1）从 Kali 官方站点 http://www.kali.org/downloads/ 下载合适的镜像；

2）插入一张空白 SD 卡。使用下面的命令挂载目录；

```
mount | grep -i vfat
```

（假设目录为 /dev/sdb，用于下一步骤。）

3）将 Kali 镜像文件拷贝到 SD 卡上；

```
dd if=kali.img of=/dev/sdb bs=512k
```

4）在移除设备前用 umount 命令卸载，并使用 sync 命令同步写操作；

```
umount /dev/sdb
sync
```

5）取出 SD 卡；

6）将装有 Kali Linux 镜像的 SD 卡插入你的 ARM 架构的计算机设备，然后从 SD 卡启动。

2.7 本章小结

本章主要介绍在大多数计算机、笔记本、USB 和微型计算机设备上如何安装 Kali Linux。安装 Kali Linux 就像骑自行车，装过一次之后，你再也不会忘记如何操作。请注意随时查询 Kali 官方网站上的文档，关注安全社区消息公告板上关于新版本、更新和新技术的开发。和安全专家、安全爱好者或者黑客用户，在网络上建立联系，开拓思路，参与新项目，同时也可以为社区用户答疑。

第 3 章 Chapter 3

软件、补丁和升级

HZ BOOKS
华章图书

章节信息

- APT 软件包处理工具
- Debian 软件包管理器
- 源代码压缩包
- Nessus 安装实用指南

本章要点

本章会讲解怎样使用 APT 软件包处理工具（apt-get）和 Debian 软件包管理器（dpkg）来维护、升级和安装自定义及第三方应用程序。

3.1 APT 软件包处理工具

APT 软件包处理工具是一个轻量级但功能强大的命令行工具，用于安装和删除软件包，通常简写为 apt-get。apt-get 会对所有安装过的软件做好记录，并且处理好依赖关系。依赖关系就是一个软件正常运行所需要的其他软件。例如，用于渗透的最佳工具 Metasploit 就依赖一门叫做 Ruby 的编程语言。如果 Ruby 没有预先安装，Metasploit 就无法启动。因此，Ruby 就是 Metasploit 的一个依赖关系。

apt-get 不但会跟踪已安装软件的依赖关系，还会在更新可用的时候跟踪软件的版本和软件之间的相互依赖关系。当一个软件包不再有用时，它会在下一次更新的时候提示用户，并

建议用户将其移除。

apt-get 的使用非常简单，但它也提供了复杂多样的功能。在软件包管理工作中，最重要的是确保 Kali Linux 的功能能够正常使用，并且都更新到了最新版本。Kali Linux 的普通用户并不需要对 apt-get 做深入的了解，只要掌握一些基本用法就可以了。

3.1.1 安装应用程序或软件包

安装额外的软件是 apt-get 命令最基本的功能了，命令非常简单易懂。安装软件包的语法如下：

```
apt-get install {package_name}
```

下面安装图像编辑软件 gimp：

```
apt-get install gimp
```

更新

每时每刻都要检查软件源，或软件库，以获得安装在 Kali Linux 上的应用程序或软件包的更新版本。我们建议你在安装任何新软件包之前都要检查更新，每次要升级操作系统或者应用程序或软件包之前都进行检查，命令语法如下：

```
apt-get update
```

升级

没有什么系统是完美的，事实上所有的主流操作系统都在不断地升级和提高，通过补丁管理来提供新功能并修补 bug。升级功能会下载并安装所有已安装软件的最新版本。所有基于 Linux 的操作系统的好处就是它们是开源的，这意味着世界上的任何一个人都可以为某个发行版提交新代码，如果你发现了一个 bug 或者发现了需要提高的地方，就可以提交新的代码以提升系统功能。这使得开源系统的补丁更新会比微软之类的大型公司更快。如前所述，在升级之前应该先进行一下更新。要升级 Kali 的软件，使用如下的命令：

```
apt-get upgrade
```

版本升级

发行版升级功能和上面说的升级功能很类似。不同的是，即使你之前没有安装一个软件，如果它已经被放进下一版的内置软件列表中了，那么这个软件以及它的依赖关系包也会被安装。例如，当使用发行版升级功能的时候，整个 Kali 的版本会从 1.0 升级到 1.n 或者 2.n。用如下的命令语法来升级 Kali：

```
apt-get dist-upgrade
```

移除

apt-get 可以用来减少系统占用的空间，或者移除某个指定的程序。我们也建议你移除所有用不到的软件包，或对操作系统来说非必需的软件包。例如，如果系统不需要 Leafpad 应用程序，那就移除它。如果是以后可能需要安装的应用程序，那就留下来。我们建议你最好删除所有非必需的软件包。你可以用如下语法来移除应用程序或软件包：

```
apt-get remove {package_name}
```

试着移除并重新安装 leafpad：

```
apt-get remove leafpad
apt get install leafpad
```

自动移除

当操作系统使用一段时间之后，旧的应用程序软件包渐渐被新的软件包替代。你可以使用自动移除功能来移除那些系统不再需要的软件包。我们建议你在每次升级或者发行版升级之后使用一次自动移除功能。使用如下的语法来运行自动移除：

```
apt-get autoremove
```

完全移除

移除和完全移除之间的区别是什么？移除功能并不会删除配置文件，而是把它们留在硬盘上以防你以后还会用到。这是有必要的，尤其是有的应用程序，例如 MySQL、Samba Server 或者 Apache，这些配置文件对应用程序的可操作性起着关键作用。然而，有时我们确实需要删除应用程序的所有文件，包括配置文件，以便我们能完全重装应用程序，并清除敏感信息的所有痕迹。使用完全移除功能用一行命令就可以清除所有的应用程序软件包和相关的配置文件。请注意，在使用完全移除功能之前应该三思，错误地使用这个功能或用于错误的应用程序将会从系统中移除所有相关的文件，造成严重的后果。要使用完全移除，请用如下的语法：

```
apt-get purge {package_name}
```

清理

当安装软件包时，系统会从软件源下载软件包，解压并安装。安装过后下载的软件包文件默认会被留在硬盘上。这些软件包文件在安装成功之后就已经没有用了，系统使用一段时间之后，它们会占用很多磁盘空间，因此应该被清理掉。你可以使用以下语法启动清理功能：

```
apt-get clean
```

自动清理

自动清理也会像清理功能那样清理系统，只是它可以自动在升级和发行版升级之后运

行，删除所有已经被新版本替换掉的旧软件包文件。例如，你现在系统上安装了应用程序 Y 的 1.0 版，升级系统之后 Y 1.0 被 Y 2.0 替换了。自动清理功能只会清理掉第一版，然而，清理功能会将两个版本的应用程序软件包都删掉。自动清理功能的语法是这样的：

```
apt-get autoclean
```

3.1.2 使用组合命令

对软件包的管理应该让工作变简单而不是变复杂。下面的命令可以确保用户安装好所有最新的补丁、软件包和更新：

1. `apt-get update && apt-get upgrade && apt-get dist-upgrade`
2. `apt-get autoremove && apt-get autoclean`

命令行中的”&&”符号可以让多条命令按顺序执行。

3.2 Debian 软件包管理器

Linux 主要的发行版都有自己的应用程序软件包管理系统。Kali Linux 基于 Debian 7.0 操作系统，并且可能需要安装第三方的应用程序，例如 Tenable 的 Nessus。Nessus 是一个漏洞扫描应用程序，可以用适用于 Debian 软件包管理器的软件包文件来安装。Nessus 的用法会在后面第 8 章中讲到。当下载此类应用程序时，请寻找 .deb 后缀名的安装包。

使用 Debian 软件包管理器和使用 APT 比起来并没有什么优势。apt-get 程序就是专门为 Debian 的软件包管理而编写的。只不过从某个经销商处购买的第三方应用程序并不会被放进 apt-get 的源里，你也无法使用 apt-get 来下载和安装他们。Kali Linux 在不安装额外软件的时候是不兼容 RPM（Red Hat Packages）的。并且我们也不推荐你在基于 Debian 的系统上使用 RPM 管理软件包。

安装

在下载了一个 .deb 软件包之后，我们需要使用 dpkg 命令安装它。绝大多数的 .deb 软件包都很简单，包括所有该应用程序所需的依赖关系。例外情况主要出现在需要授权的软件，经销商会要求你做额外的步骤，这些都会有相应的文档教你怎么正确安装。所以在安装前请确保你读过经销商给你提供的文档。安装的命令是：

```
dpkg -i {package_name.deb} /{target_directory}
```

卸载

移除一个软件包（–r）和完全移除一个软件包（–P）的处理方式和 APT 非常相似。你可以这样移除一个软件包：

```
dpkg -r {package_name.deb}
```

对于 Debian 软件包管理器，完全移除软件包的命令和移除也很像，可以使用这样的命令：

```
dpkg -p {package_name.deb}
```

检查已安装的软件包

Debian 软件包管理器拥有一项 APT 没有的强大功能，就是显示已安装或已删除的软件包当前的状态。当在 dpkg 中使用 list 功能时，输出中每行开头会有两个或三个字符的代码来标明软件包当前的安装状态。例如，当对 Leafpad 使用此命令时，你可以看到该软件包已经被移除了，但是配置文件还在（如图 3.1 所示）。

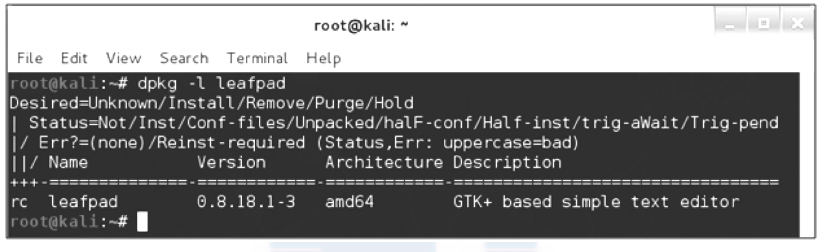


图 3.1　Leafpad 已被移除

在使用命令 dpkg –P leafpad 之后，这个软件包的配置文件就被移除了。图 3.2 显示 Leafpad 被完全移除后检查该软件包的结果。

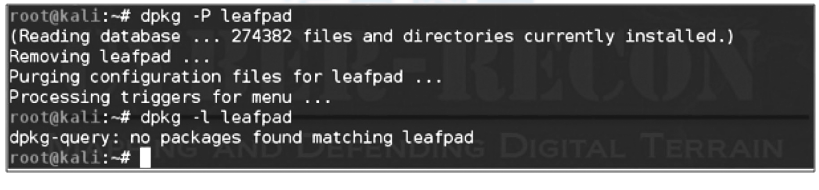


图 3.2　Leafpad 已被完全移除

要查看已安装或移除的软件包的状态，使用如下的语法：

```
dpkg -l {package_name}
```

你还可以使用如下的命令查看已安装的软件包更详细的信息：

```
dpkg -p {package_name}
```

在使用命令的时候需要区分大小写。小写的 p 会将软件包的信息输出到屏幕上。大写的 P 会完全移除软件包，并且不做任何提示。

3.3 TAR 压缩包

TAR 一词，起源于早些年前的 UNIX 系统，顾名思义，它开始是把多个文件写入磁带存档（Tape ARchive）。尽管需要把多个文件写到磁带上的人很少，但是用 TAR 应用程序将多个文件放入一个文件容器中这个功能就比较常用了，这可以使得文件传输更简单。而且，这些文件还可以使用 gzip 压缩，来减小整个文件包的体积。有的第三方或者开源项目可以通过源代码压缩包的形式下载，你可以通过 .tar 或者 .tar.gz 扩展名识别出它们。

在渗透测试的过程中，会产生大量的扫描文档、屏幕截图、自定义脚本和客户端文档。使用 TAR 文件包功能就可以更加方便地收集、管理和传输信息了。我们也建议你将渗透测试的所有记录放在一个安全的地方存储至少五年，或者由所在地法律决定的时间长度。客户也可能在协议中规定结果的留存需求，这些通常会在渗透测试的授权合同（ROE）上。和 ROE 有关的话题会在第 11 章中详细说明。如果一个公司或承包商对渗透测试的响应非常积极，那测试文档很快就会堆积如山并超出控制。TAR 文件包功能可以为你提供一个将记录分别储存并备份的管理系统。

创建一个 tar 文件

创建 tar 文件包可以非常简单，也可以非常复杂。你需要记住的就是 tar 命令的原始功能是发送文件到 TAR。如果要使用 tarball 系统的高级功能，请查看手册（使用 man tarball）。这本书中我们只介绍创建 tarball 文件最基础的用法，而且这些信息在其他以 Linux 为基础的平台上也是通用的。下面的步骤提供了一个如何创建 tar 文件包的示范：

首先为文件创建一个目录。这里我们使用 mkdir 命令创建 tar-demo1 目录：

```
mkdir tar-demo1
```

然后在该目录中创建一些文件用来演示 tar 命令。这里右尖括号（>）可以用来创建内容是”Hello World”的文件。第一个文件起名叫 file1，然后通过这个方式使用相同的语法创建一些同样的文件，只是最后的数字不同。这样创建文件也可以将文件直接放入指定的目录中，在这个例子中目录是 tar-demo1：

```
echo “Hello World” > tar-demo1/file1
echo “Hello World” > tar-demo1/file 2
```

然后切换到你想要创建 Tar 文件包的目录。在这个例子中还是 tar-demo1 目录：

```
cd tar-demo1
```

然后生成一个包括当前目录下所有文件的 tar 文件包。在这个例子中通配符（*）表明该目录下所有的文件都应该被加入该 tar 文件中。

```
tar -cf tarball-demo.tar *
```

你可以使用 tar –tf 命令来列出 tar 文件包的内容列表：

```
tar -tf tarball-demo.tar
```

解压缩 tar 文件

从压缩包中解压文件就像写数字一样简单，然而，关键是存放文件的位置信息。从压缩文件包中提取文件放置在工作目录，如果这个包是在根目录中，那么解压文件就结束了。我们在解压文件包时应该使用“ -C”关键字，因该养成这样的一个好习惯，这是一个好的建议。“-C”关键字允许我们指定解压后文件存放的位置。

新建一个目录用来存放被提取的文件。这个例子中目标目录是 tar-demo2：

```
mkdir /root/tar-demo2
```

提取文件到指定的目录：

```
tar -xf /root/tar-demo1/tarball-demo.tar -C /root/tar-demo2/
```

确认提取的文件是之前指定的那些文件：

```
ls /root/tarball-demo2/
```

压缩 tar 文件

tar 文件包可以在创建时经由几种不同的算法压缩。一个标准的算法是 gunzip，就是我们熟知的 gzip。它可以通过如下命令使用。

新建一个目录，这里是 tar-demo3：

```
mkdir tar-demo3
```

现在把你的文件放进目录中。就像之前那样用 echo 命令来产生用于演示的文件：

```
echo “Hello World” > tar-demo3/file1
```

移动到你想生成压缩包的目录，这里还是 tar-demo3 目录：

```
cd tar-demo3
```

将当前目录中的所有文件压缩成一个文件包。这个可以通过使用 –czf 选项来实现。tar 命令的选项用于确保正确生成 tarball，其中的 c 选项是创建一个新存档文件，z 是压缩这个文件，f 是指定选项后的参数（ tarball-demo.tar.gz）作为创建的压缩包的文件名。同样，这里的通配符（*）告诉 tar 命令当前目录下的所有文件都应该放进压缩包中：

```
tar -czf tarball-demo.tar.gz *
```

使用 t 和 f 选项列出压缩包中的内容。t 选项是列出 tar 文件包的内容，f 选项和上面一样，是指定后面的参数为要查看的文件名：

```
tar -tf tarball-demo.tar
```

从压缩的 tar 文件包中提取文件和从未压缩的文件包中提取文件是一模一样的。唯一的不同是使用 x 选项来表明 tar 命令是从压缩包中提取文件。我们通常将压缩过的文件包的后缀名改

为 .gz 来表示它是压缩过的，不过这不是必须的。请注意这里文件的后缀名分为两段（.tar.gz），这是 Linux 完全兼容的用法，并且也是压缩文件的标准表示。要解压缩 tar 文件，使用如下命令：

```
tar -xf {tarball_file.tar.gz} -C {directory_for_files}
```

3.4 Nessus 安装实用指南

Tenable，这个在安全社区广受尊敬的公司，制作了一个称为 Nessus 的漏洞扫描应用程序。这个应用程序有两个版本，提供了不同的功能和支持，分别是专业版和家庭版。专业版提供了更多的插件来进行合规性检查、SCADA 和配置检查，非常适合团队使用。在本书中，我们将要安装的是 Nessus Vulnerability Scanner 的家庭版。Nessus 详细的使用方法会在第 8 章讲解。不过现在安装 Nessus 有助于我们巩固本章学习的知识。

安装 Nessus 的准备工作：更新并清理系统

在终端窗口中输入如下的命令：

```
apt-get update && apt-get upgrade && apt-get dist-upgrade
apt-get autoremove && apt-get autoclean
```

安装并配置 Nessus

从 http://www.nessus.org/download 下载 Nessus5.0 或更高版本。选择对应 32 位或 64 位操作系统下的 Debian 软件包格式。阅读订购协议，如果你同意的话，点击“Agree”按钮。如果不同意订购协议，Nessus 就无法安装。记住下载下来的文件存放的目录，过会儿还需要用到以便完成安装。

在终端窗口中输入如下命令来安装：

dpkg -i ~/{Download_Location}/Nessus-{version}.deb

更加详细的安装指南请查看附录 A。

3.5 本章小结

本章涵盖了 Kali Linux 系统中软件包管理的基础技能。APT 是一个功能非常强大的命令行工具，能够将软件包、更新和补丁的管理自动化。Debian 软件包管理器（dpkg）是 APT 的底层系统。只要对这些工具有基本的理解和熟悉，就可以将系统维护在最新状态和安装新软件了。

本章中提到的工具的高级用法，可以通过查询用户手册来学习。在终端中阅读手册或者在网上找到相应的官方网站都可以查看手册。这些工具都具有毁掉整个系统的能力，并且运行时不会做任何提示，事后也无法复原。所以我们建议在你熟练的使用这些工具之前，先在一个单独的系统或者虚拟机上练习它们。